

-ISO 27001:2022--7.1 Recursos .-

La organización debe determinar y proporcionar los recursos necesarios para el establecimiento, implementación, mantenimiento y mejora continua del sistema de gestión de seguridad de la información (SGSI).

La organización ha determinado y proporciona los recursos necesarios para el SGSI de la siguiente manera:

Recursos humanos:

Se dispone de un equipo de seguridad de la información liderado por el Responsable del SGSI (con competencias en gestión de riesgos, normativas ISO 27001, controles de acceso y respuesta a incidentes) y un Administrador de Sistemas (con experiencia en entornos cloud, redes, sistemas operativos y bases de datos). Ambos cuentan con equipos portátiles corporativos cifrados y protegidos mediante autenticación multifactor y políticas de bloqueo remoto.

Recursos físicos:

- Las oficinas técnicas y la sala de servidores están ubicadas en un área restringida con control de acceso mediante tarjeta electrónica y videovigilancia.
- Todo el perímetro de las instalaciones cuenta con sistema de alarma conectado a central receptora.
- Se dispone de dos centros de procesamiento de datos (CPD) redundantes:
- CPD principal: Aloja los servidores de aplicaciones críticas (ERP, CRM) y bases de datos corporativas.
- CPD secundario (DRP): Réplica del principal para garantizar la disponibilidad ante contingencias.
- Redes de área local segmentadas por departamentos (finanzas, RRHH, operaciones, TI) con conexión cableada e inalámbrica bajo VLANs y políticas de firewall interno.
- Puestos de trabajo estandarizados para cada empleado según su rol (analistas, desarrolladores, administrativos, directivos).

Recursos tecnológicos:

- Sistemas operativos Windows Server y Linux en servidores, según criticidad del servicio.
- Bases de datos relacionales (PostgreSQL y MySQL) para aplicaciones transaccionales y analíticas.
- Plataforma de colaboración corporativa (Nextcloud o SharePoint) para gestión documental.
- Servidor de correo electrónico con filtrado antimalware y antispam (por ejemplo, Microsoft 365 o servidor SMTP local).
- Clientes de navegación segura (Firefox ESR y Chrome con políticas de seguridad).

- Herramientas de monitorización (Zabbix o Nagios) y SIEM (Wazuh) para detección de incidentes.

Recursos organizativos y procedimentales:

- Roles y responsabilidades definidos en la matriz RACI del SGSI.
- Control de acceso basado en roles (RBAC) con autenticación integrada mediante directorio activo (LDAP/AD).
- Procedimiento de gestión de cambios y configuración de activos críticos.
- Políticas de respaldo periódico (diario, semanal) con almacenamiento fuera del sitio.
- Plan de respuesta a incidentes y plan de continuidad de negocio probado anualmente.
- Programa de concienciación y formación en seguridad para todo el personal.